



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Gitea CVE-2026-60004 Remote Code Execution KEV Daily Priority Update 2026-09-02

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-09-02
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Gitea CVE-2026-60004 Remote Code Execution KEV Daily Priority Update 2026-09-02 - CVE / Vulnerability Threat Intelligence Report

Published: 2026-09-02 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Affected Products and Exposure
7. Mitigation and Workarounds
8. Detection Engineering
 - 8.1. Detection Logic Summary
9. Threat Hunting
 - 9.1. Hunt Hypothesis
10. MITRE ATT&CK Mapping
11. Validation / Lab Testing
12. Recommended Actions Summary
13. References

Gitea CVE-2026-60004 Remote Code Execution KEV Daily Priority Update 2026-09-02

> **Daily automation freshness note (2026-09-02):** This daily update preserves the cited source-backed technical findings from the current reporting window and refreshes the publication identity for today's defender-prioritization cycle. No uncited IOCs, CVEs, victim claims, or exploitation claims were added.

> **Current-day automation note (2026-08-31 UTC):** This report was created for today's Lost Boys Cyber automated intelligence coverage. Source review favored material published or updated in the last 24-72 hours; where supporting sources are broader guidance, they are cited as context rather than proof of a new event.

1. Executive Summary

Gitea CVE-2026-60004 Remote Code Execution KEV Daily Priority Update - 2026-08-31 is prioritized for 2026-08-31 because public reporting indicates exploited or immediately actionable exposure for defender teams. The affected technology often sits near authentication, management, source-code, or edge-service workflows, so compromise can become credential theft, web-shell deployment, lateral movement, or downstream supply-chain abuse.

Lost Boys Cyber assesses this item as **Critical** priority for organizations with exposed or business-critical Gitea self-hosted Git service deployments. The immediate path is inventory, patch validation, log review for exploitation indicators, secret rotation where compromise cannot be ruled out, and temporary isolation of exposed interfaces when patching cannot complete immediately.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-60004
Product / Component	Gitea self-hosted Git service
Weakness	Reported critical code-injection / remote-code-execution path affecting exposed self-hosted Git services; public reporting associates the flaw with diff/patch and Git-hook abuse paths.
Severity	Critical daily priority
Fixed / Mitigated Versions	Upgrade to Gitea 1.27.1 or later per public reporting; validate final version applicability against the vendor advisory and local inventory.
Exploitation Status	CISA KEV and active exploitation are reported in multiple public sources; one reported attack path involved miner-like payload delivery.
Daily Selection Rationale	Exposed management/developer/edge technology with active exploitation reporting and short remediation window.

3. Source Review & Confidence

Source	Contribution	Confidence
CISA KEV alert	Adds exploited vulnerabilities to KEV, including current emergency-remediation context.	High
The Hacker News	Reports CVE-2026-60004 active	High

	exploitation and miner-like payload context.	
Quasa	Summarizes affected Gitea versions, open-registration risk, and remediation priorities.	Medium
RedEye Security	Provides exploitation-window and KEV deadline context.	Medium

Confidence is ****high**** that this is a defender-priority item for today based on multiple public sources. Exact version applicability and maintenance language should still be validated against canonical vendor and CVE records before change-control execution.

4. Vulnerability Details

The vulnerability should be treated as externally actionable where Gitea self-hosted Git service is reachable from the internet, lower-trust partner networks, shared administration enclaves, or compromised internal user paths. Public reporting describes an application/appliance flaw that may enable attacker-controlled behavior; this report intentionally avoids exploit reproduction and focuses on defensive validation.

5. Attack Scenarios

Scenario	Defender Concern
Internet-facing affected service exploited before patching	Remote code execution, web shell, miner/dropper, or service-account compromise.
Authenticated or lower-trust internal user reaches the vulnerable service	Privilege escalation into source code, secrets, or management planes.
Patched asset with pre-patch exposure	Residual persistence, stolen tokens, or delayed exfiltration from earlier compromise.

6. Affected Products and Exposure

Exposure Pattern	Why It Matters
Publicly reachable Gitea self-hosted Git service	Highest exploitation likelihood and easiest scanning path.
Internal high-value workflow	Management/developer services often hold credentials and trusted network paths.
Third-party managed instance	Supplier compromise can affect many downstream organizations.

7. Mitigation and Workarounds

Priority	Owner	Action
Critical	Infrastructure / Platform	Inventory Gitea self-hosted Git service, confirm external exposure, and apply vendor fixed versions.
High	SOC	Review logs for child-process launches, new admin users, web shells, suspicious file writes, and unusual outbound traffic.
High	IAM / Secrets	Rotate tokens and service credentials where

		exploitation cannot be ruled out.
Medium	Risk / Vendor Management	Request remediation evidence from managed providers and track affected assets to closure.

8. Detection Engineering

8.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Suspicious child process from service account	DeviceProcessEvents / Sysmon / Linux auditd	Identify application-to-shell execution.
Unexpected outbound traffic from product host	DeviceNetworkEvents / proxy / firewall	Identify payload retrieval, C2, or exfiltration.
New files in web, plugin, hook, or appliance directories	File telemetry / EDR	Find persistence or post-exploitation tooling.
<pre> title: CVE-2026-60004 Suspicious Post Exploitation Behavior status: experimental logsource: product: linux category: process_creation detection: selection_shell: Image endswith: - '/sh' - '/bash' - '/curl' - '/wget' - '/python' selection_context: CommandLine contains: - 'CVE-2026-60004' - 'bash -c' - 'sh -c' - 'curl ' - 'wget ' condition: selection_shell or selection_context level: high </pre>		

9. Threat Hunting

9.1. Hunt Hypothesis

An attacker exploited an affected public-facing service and launched shell tooling or created persistence before patching completed.

<pre> DeviceProcessEvents where Timestamp > ago(14d) where ProcessCommandLine has_any ('CVE-2026-60004', 'curl ', 'wget ', 'bash -c', 'sh -c', 'python -c') where InitiatingProcessAccountName has_any ('gitea','nsroot','www-data','nginx','apache','svc','root') project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessAccountName, FileName, ProcessCommandLine </pre>
<pre> DeviceNetworkEvents where Timestamp > ago(14d) where InitiatingProcessCommandLine has_any ('curl','wget','powershell','bash','sh') summarize count(), min(Timestamp), max(Timestamp), make_set(RemoteUrl, 20), make_set(RemoteIP, 20) by </pre>

```
DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine
| order by count_ desc
```

10. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Public exploitation of exposed application/appliance surface.
T1059	Command and Scripting Interpreter	Post-exploitation shell/script execution hunt focus.
T1105	Ingress Tool Transfer	Payload retrieval patterns via curl/wget or similar tools.
T1078	Valid Accounts	Service-token and credential pivot risk after compromise.

11. Validation / Lab Testing

No exploit reproduction was performed for this daily report. Validation should use approved vendor checks, authenticated version inventory, exposure scanning, and log review.

12. Recommended Actions Summary

Priority	Action	Evidence to Retain
1	Patch or isolate affected exposed systems.	Asset list, version output, change ticket.
2	Hunt for pre-patch exploitation.	SIEM query results and reviewed alerts.
3	Rotate secrets if compromise cannot be excluded.	Token rotation records and owner attestation.
4	Add monitoring for exploit-class behavior.	Deployed Sigma/KQL mapping and alert owner.

13. References

- [CISA KEV alert](<https://www.cisa.gov/news-events/alerts/2026/08/26/cisa-adds-six-known-exploited-vulnerabilities-catalog>) — Adds exploited vulnerabilities to KEV, including current emergency-remediation context.
- [The Hacker News](<https://thehackernews.com/2026/08/critical-gitea-rce-actively-exploited.html>) — Reports CVE-2026-60004 active exploitation and miner-like payload context.
- [Quasa](<https://quasa.io/insights/gitea-s-rce-is-now-exploited-open-registration-widens-the-door>) — Summarizes affected Gitea versions, open-registration risk, and remediation priorities.
- [RedEye Security](<https://threat-intelligence.redeyesecurity.com/blog/gitea-diffpatch-rce-cve-2026-60004-exploited-2026>) — Provides exploitation-window and KEV deadline context.